



Fundamentals of Information Security

By Dr. Shweta Mittal



Why this course is important?

- In this era of ubiquitous computing, where we are connected to each other through so many computing devices, it is important to protect our data.
- Now, Data protection can be divided into 2 parts:
 - PC Centric
 - Network Centric



1. PC-centric:

- Safety of sensitive data from unauthorized access within your computing device
- Mobile Phones, Laptops, Bank Cards etc.

2. Network-Centric

- Protect data during transmission between computer to computer
- Distributed Computing



Basic Components of Security



Confidentiality

- Concealment of information or resources.
- Protection from unauthorized disclosure.
- The need for keeping information secret arises from the use of computers in sensitive fields such as government and industry.
- For example, military and civilian institutions in the government often restrict access to information to those who need that information.
- All types of institutions keep personnel records secret.

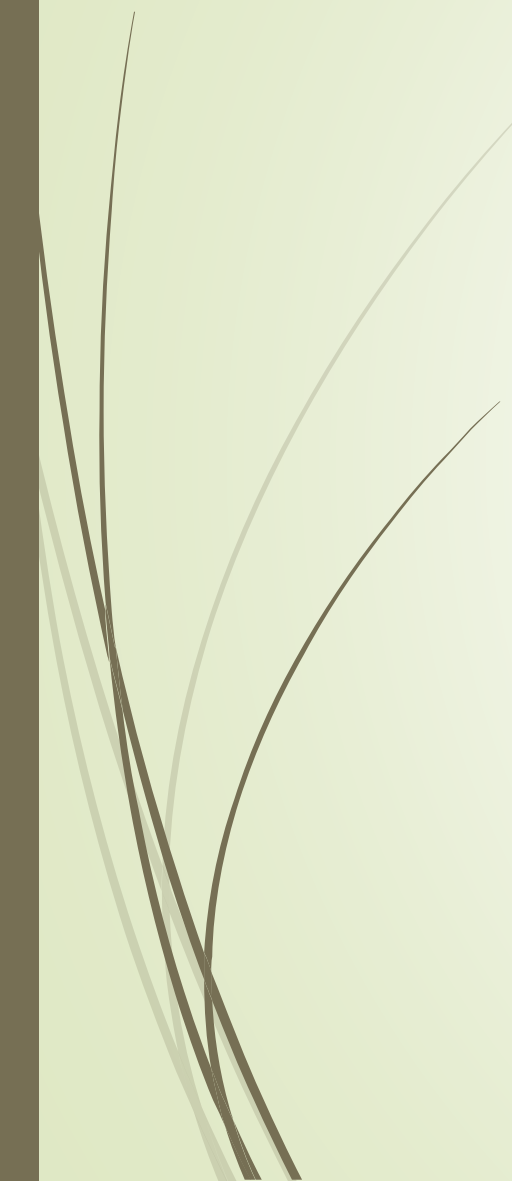
- 
- 
- One way of achieving confidentiality is by implementing Access control mechanisms, which can prevent processes from illicitly accessing information.
 - E.g., some software may have admin-level access, whereas some may have user-level permissions only.
 - However, data protected only by these controls can be read when the controls fail or are bypassed, i.e., the data becomes visible
 - Another option is to use **cryptography**, which scrambles data to make it incomprehensible.
 - A *cryptographic key* controls access to the unscrambled data, but then the cryptographic key itself becomes another datum to be protected.

- 
- 
- **Resource hiding** is another important aspect of confidentiality.
 - E.g., Sites often wish to conceal their configuration as well as what systems they are using.
 - Organizations may not wish others to know about specific equipment (because it could be used without authorisation or in inappropriate ways).
 - Company may not want others to know what resources it is using.
 - Access control mechanisms provide these capabilities as well.



► Integrity

- Refers to the trustworthiness of data or resources, and it is usually phrased in terms of preventing improper or unauthorised change, i.e., protection from modification.
- Includes data integrity (the content of the information) and origin integrity (the source of the data, often called *authentication*).
- Integrity includes both the correctness and the trustworthiness of the data.
- The origin of the data (how and from whom it was obtained), how well the data was protected before it arrived at the current machine, and how well the data is protected on the current machine all affect the integrity of the data.
- E.g., A newspaper may print information obtained from a leak at the White House but attribute it to the wrong source. The information is printed as received (preserving data integrity), but its source is incorrect (corrupting origin integrity).

- 
- 
- Integrity mechanisms fall into two classes:
 - *Prevention mechanisms*
 - *Detection mechanisms*



■ Prevention Mechanisms

- Protect data from unauthorized changes.
- Stop users from changing data without permission.
- Stop authorized users from making changes they are not allowed to make.
- Example:
 - A hacker enters an accounting system and changes financial data: (**Unauthorized user**).
 - An accountant changes company records to secretly transfer money: (**Authorized user, but unauthorized action**).
- Therefore, security must protect data from both unauthorized users and misuse by authorized users.



■ **Detection Mechanisms**

- Detect and report when data integrity is violated.
- They do not prevent the problem, they only identify that the data may no longer be trustworthy.
- They can check:
 - System activities to find suspicious actions.
 - Data itself to check whether it follows expected rules.
- The mechanisms may report the actual cause of the integrity violation (a specific part of a file was altered), or they may simply report that the file is now corrupt).



➤ Availability

- Ensuring timely and reliable access to and use of information to authorized entities.
 - An unavailable system is at least as bad as no system at all.
 - The security aspect of availability means that someone may deliberately stop access to data or a service by making it unavailable. For example, this can happen through DoS (Denial-of-Service) attacks.
 - Attempts to block availability are called **DoS attacks**.
 - These attacks can be difficult to detect. The analyst must determine whether the unusual activity is an intentional attack or just a normal system-related problem.
- 



Security Principles

1. **Confidentiality** – Only authorized people can access the data.
2. **Integrity** – Data should not be changed without permission.
3. **Availability** – Data and services should be available when needed.
4. **Authentication** – Verifies that a user is who they claim to be.
5. **Non-repudiation** – Ensures that a person cannot deny performing an action or sending a message.

- 
- **Authentication** = Who are you?
 - **Authorization** = What are you allowed to do?

- For example, you log in to your college portal:

Authentication: You enter your username and password. The system checks that you are really you.

Authorization: After logging in, the system decides what you can access. For example, you may be allowed to view your marks, but you cannot change your marks.

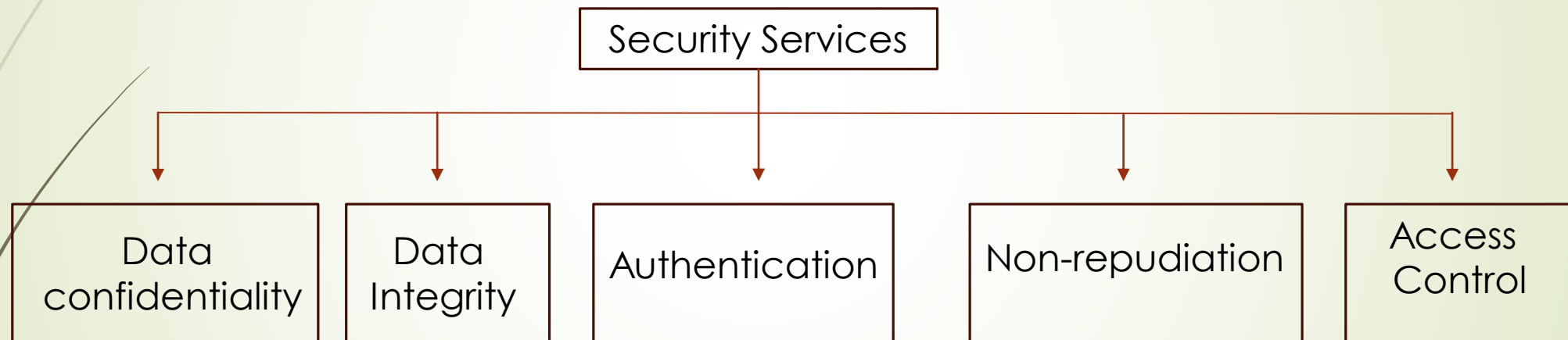


3 Aspects of Information Security

1. Security Service
 2. Security Mechanism
 3. Security Attack
- 

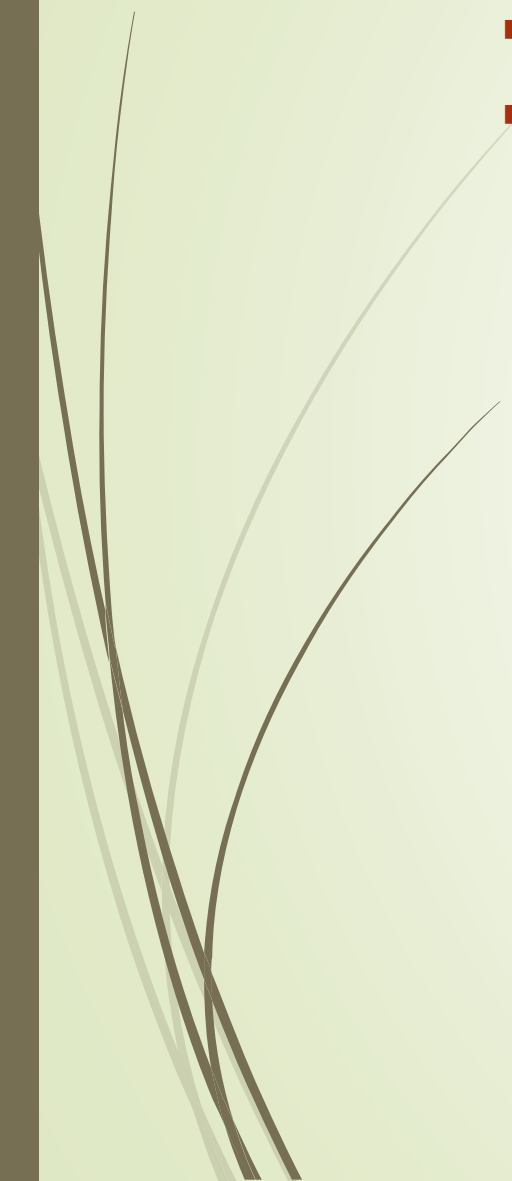
Security Service

- It is something that enhances the security of the data processing systems and the information transfer of an organization.
- Security service is intended to counter security attacks.





Security Mechanisms

- They are design to prevent or recover from a security attack.
 - 8 Security Mechanisms:
 1. **Encipherment** – Protects data from unauthorized access.
 2. **Digital Signature** – Verifies the sender and ensures data is not changed.
 3. **Access Control** – Controls who can access data or resources.
 4. **Data Integrity** – Ensures data is not changed without permission.
 5. **Authentication Exchange** – Verifies the identity of a user or system.
 6. **Traffic Padding** – Adds extra data to hide communication patterns.
 7. **Routing Control** – Selects secure routes for sending data.
 8. **Notarization** – Uses a trusted third party to verify an action.
- 



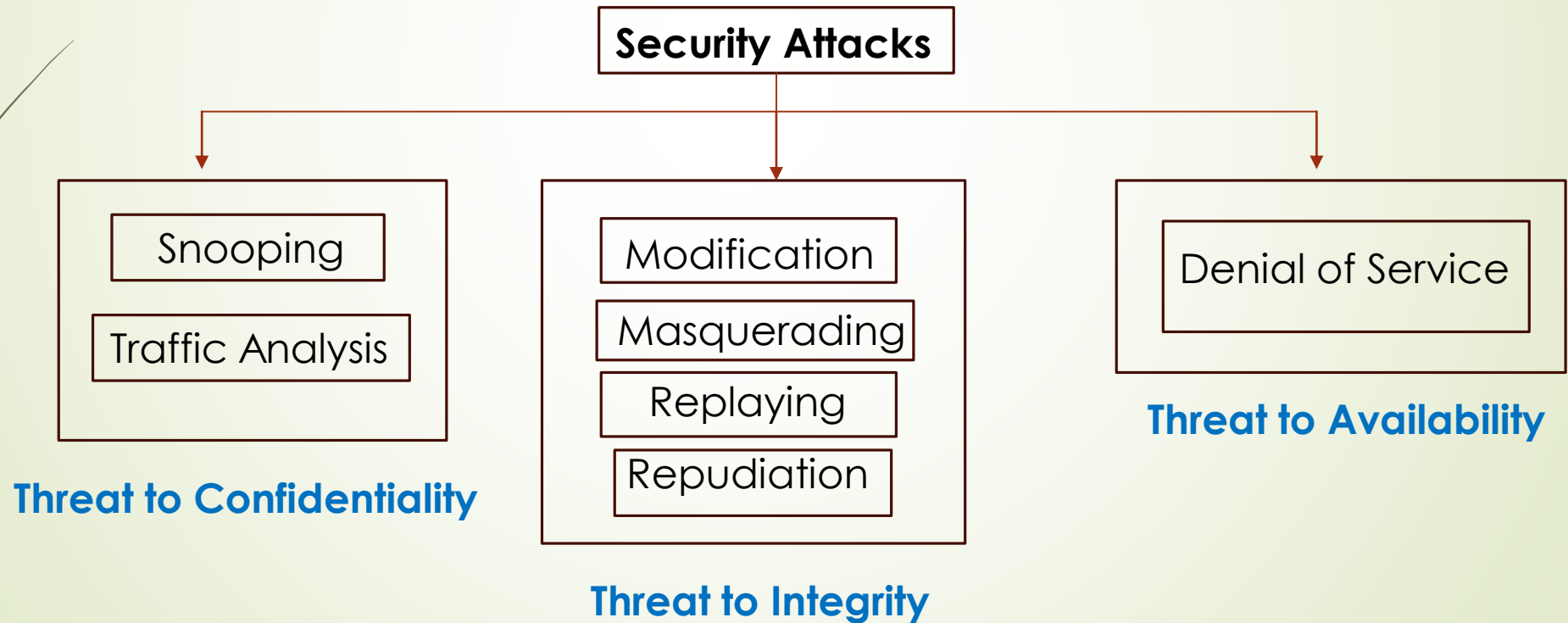
Threats and Attacks

- A **threat** is a potential violation of security. The security violation does not have to actually happen for it to be called a threat.
- Actions that could cause a security violation are called **attacks**.
- Those who execute such actions, or cause them to be executed, are called **attackers**.
- For e.g., *SQL Injection (SQLI) attack* that uses malicious SQL code to access or change information in a database. It takes advantage of input that is not properly checked. The attacker enters SQL commands through a web application, which are then executed by the back-end database.
- **Threat:** Non-validated input is present.
- **Attack:** SQL Injection attack.

Security Attacks

■ Non-Cryptanalytic Attacks

They do not exploit the mathematical weakness of the cryptographic algorithm.





Passive Attacks v/s Active Attacks

➤ **Passive Attack**

- Attacker only observes or monitors data.
- Does not change the information.
- Main target: Confidentiality

➤ **Active Attack**

- Attacker changes, deletes, or disrupts data.
- Can affect the system or network.
- Main target: Integrity & Availability